

Section 01

Industrial Security (Bachelor)



Section 01 – Introduction to Industrial Security

Introduction to Industrial Security

Lecture Notes

Department of Computer Science

2026-05-18

Industrial Security (Bachelor)

Section 01

Industrial Security (Bachelor)



Section 01 – Introduction to Industrial Security

Introduction to Industrial Security
Lecture Notes
Department of Computer Science

- 1 Cyber-Physical Foundations
- 2 Context and History
- 3 Threat Setting and Misconceptions

By the end of this section you will be able to

- Define Operational Technology (OT) and contrast it with Information Technology (IT).
- Identify the core components of an Industrial Control System (ICS).
- Explain why the CIA triad is re-ordered for industrial environments.
- Place industrial security in its historical and economic context.
- Recognise common misconceptions about ICS security.

1

Cyber-Physical Foundations

What is Industrial Security?

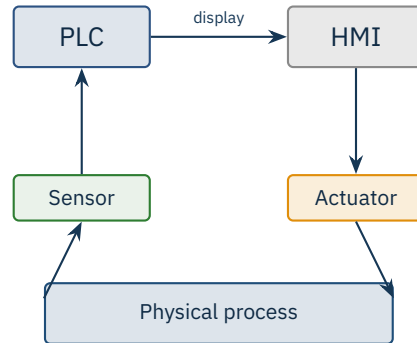
01

Definition

Industrial security is the protection of cyber-physical systems — computers that monitor and control machines in the physical world.

Sectors: power, water, oil & gas, manufacturing, transport, building automation.

A breach has consequences in *atoms*, not just in *bits*.



2026-05-18

Industrial Security (Bachelor) Cyber-Physical Foundations

What is Industrial Security?

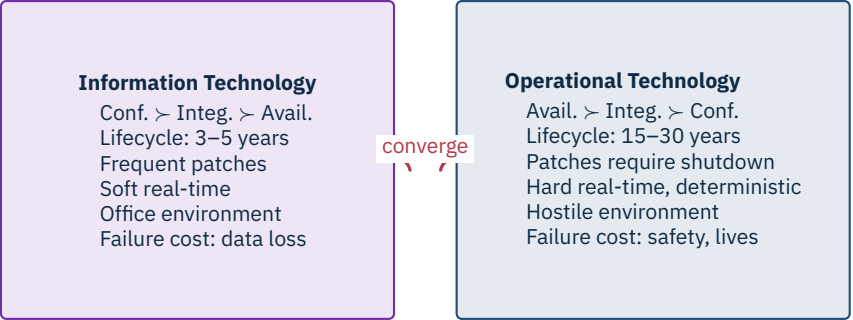
Frame this as “computers controlling things you can break with a wrench.” That tangibility hooks IT students who think of security as data confidentiality. The diagram on the right is the canonical sense-decide-act loop — come back to it in every later section; the PLC, the sensor, the actuator and the physical process are the four nouns of this course. Pre-empt the misconception that this is “just SCADA” or “just embedded systems” — it is the coupling to physics that makes the discipline distinct. Ask the room: “What’s the worst thing that could happen if your CRM goes down for a day versus your refinery?” The productive disagreement that follows sets up the IT-vs-OT contrast on the next slide.

What is Industrial Security?

Definition
Industrial security is the protection of cyber-physical systems — computers that monitor and control machines in the physical world.

Sectors: power, water, oil & gas, manufacturing, transport, building automation.
A breach has consequences in *atoms*, not just in *bits*.

```
graph TD; Sensor[Sensor] --> PLC[PLC]; PLC -- display --> HMI[HMI]; HMI --> Actuator[Actuator]; Actuator --> PhysicalProcess[Physical process]; PhysicalProcess --> Sensor;
```



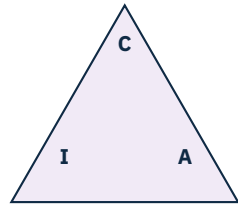
2026-05-18

Industrial Security (Bachelor)
Cyber-Physical Foundations

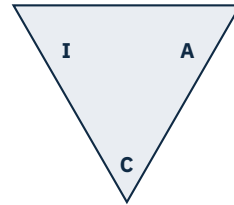
IT vs. OT — Two Different Worlds

The lifecycle row is the one that surprises students the most — a Siemens S7-300 commissioned in 1996 may still be running a water treatment plant today, while their laptop is on a three-year refresh. Drive the patching point hard: in IT you reboot on Tuesday, in OT you schedule a shutdown two years in advance and budget six figures for the production loss. The “hostile environment” line means heat, vibration, dust, EMI — not adversaries; clarify that explicitly because students conflate the two. The “converge” arrow is the whole reason this course exists: the worlds are colliding and neither side’s playbook works alone. Ask: “Whose responsibility is a patch on a PLC — the IT team or the plant engineer?” That question has no clean answer and that is the point.





IT priorities



OT priorities

Remember

In OT, **availability** and **safety** dominate the CIA triad. A blocked alarm can blind an operator to a runaway reactor.

2026-05-18

Industrial Security (Bachelor)
└ Cyber-Physical Foundations

└ The CIA Triad – Inverted for OT

The flipped triangle is deliberately visual — many students have memorised C-I-A in that order since their first security course and need a moment to accept that it is genuinely inverted here. The Bhopal-style anecdote works well: a denial-of-service against an alarm HMI is not an inconvenience, it is a path to a mass-casualty event. Note that *safety* is a fourth letter many practitioners append (S as in AIC+S, or the IEC 62443 “HSE” framing). Pre-empt the misconception that confidentiality does not matter in OT — it does, but only after the plant is still running and the readings are still trustworthy. Transition cue: “Now that we know what we are protecting, let’s see how we got here” — which leads into the history timeline.

The CIA Triad – Inverted for OT

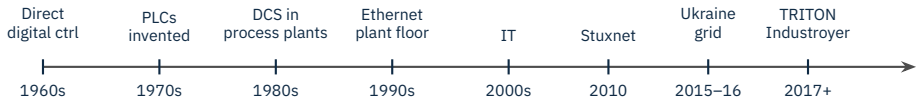
IT priorities

OT priorities

Remember
In OT, **availability** and **safety** dominate the CIA triad. A blocked alarm can blind an operator to a runaway reactor.

2

Context and History



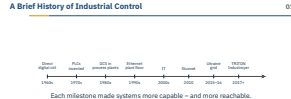
Each milestone made systems more capable – and more reachable.

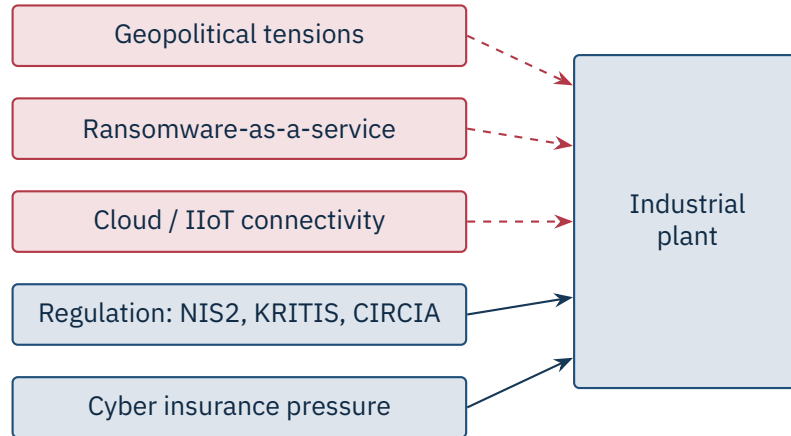
2026-05-18

Industrial Security (Bachelor)
└ Context and History

└ A Brief History of Industrial Control

Anchor the timeline with two human stories: Dick Morley building the first Modicon PLC in 1968 to replace relay logic on a GM assembly line, and the 2010 Stuxnet discovery by VirusBlokAda in Belarus. The 1990s Ethernet jump is the moment the air gap started leaking – before that, plant networks spoke proprietary serial buses no IT engineer could touch. TRITON / TRISIS (Schneider Triconix safety controllers, Saudi petrochemical plant, 2017) is the one the room often hasn’t heard of – emphasise it is the first malware that targeted a Safety Instrumented System, i.e. the thing designed to prevent loss of life. Ask: “Why did it take until 2010 for the first public ICS-targeted malware – or did it?” That opens the door to the “we just don’t see them” counter-argument. This sets up why the threat picture today looks different.





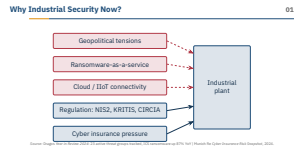
Source: Dragos Year in Review 2024: 23 active threat groups tracked, ICS ransomware up 87% YoY | Munich Re Cyber Insurance Risk Snapshot, 2024.

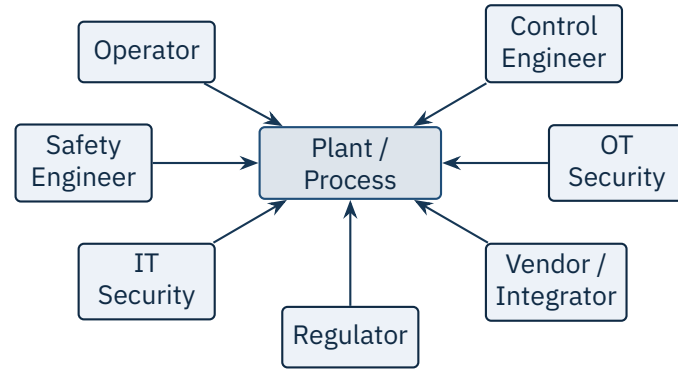
2026-05-18

Industrial Security (Bachelor) └ Context and History

└ Why Industrial Security Now?

The top three boxes are push factors — attackers moving in — and the bottom two are pull factors making defenders finally act. Name the regulations explicitly: NIS2 is the EU directive (transposition deadline was October 2024), KRITIS is the German implementation under the BSI, and CIRCIA is the US reporting law signed in 2022. Cyber insurance is doing more for OT hygiene than any regulator — premiums double or coverage is refused if you cannot prove segmentation and asset inventory. Pre-empt the cynicism that “regulation is just paperwork” — the NIS2 board-level liability provisions have genuinely changed who answers the security questions in industrial firms. Transition: “So who actually has to deal with all of this in a plant?” — that leads into the stakeholder map.





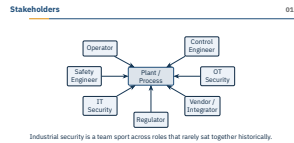
Industrial security is a team sport across roles that rarely sat together historically.

2026-05-18

Industrial Security (Bachelor)

└ Context and History

└ Stakeholders



Spend time on the cultural gap: the control engineer wears safety boots and has signed off on a hazard analysis; the IT security analyst has never been on the plant floor and may not know what a relief valve looks like. The safety engineer is the one who can say “no” to anything — they have legal authority under IEC 61511 that no one else in the room has, and a smart security programme aligns with them rather than around them. Vendors and integrators (Siemens, Rockwell, Schneider, ABB, Honeywell, Yokogawa) often hold the only credentials that can touch the controllers, which is a privileged-access problem on its own. Pre-empt the misconception that the OT security team owns everything — realistically they are translators and facilitators across these other roles. Ask: “Who in this list would you trust to approve a firmware update at 2am?” — the answer is rarely the security team.

3

Threat Setting and Misconceptions

“We’re air-gapped, so we’re safe.”

“Our protocols are obscure; nobody understands them.”

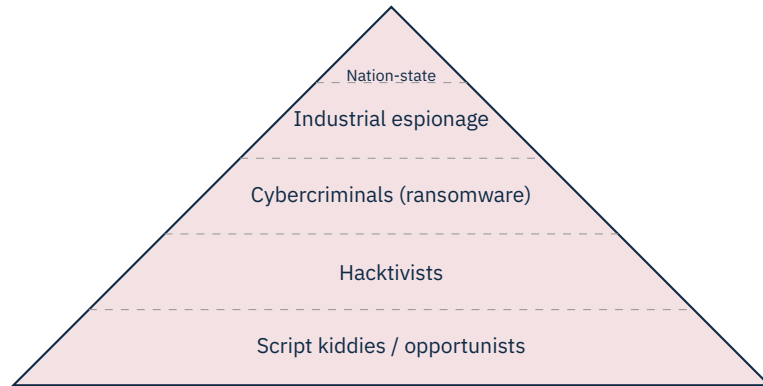
“We’ve never been attacked, so we’re fine.”

“IT tools will solve OT problems.”

“Patching solves everything.”

“Compliance equals security.”

Walk through each line as a story rather than a refutation. Air-gap: Stuxnet crossed an air gap via USB sticks carried by contractors into Natanz — and Shodan today lists tens of thousands of supposedly-air-gapped PLCs. Security-by-obscurity: Modbus, DNP3, S7comm and Profinet are now first-class Wireshark dissectors, and Claroty / Dragos / Nozomi all ship out-of-the-box parsers. “Never been attacked” usually means “never detected” — most ICS environments have no logging worth the name. “IT tools will fix it”: running a Nessus active scan against a Siemens S7-1200 has crashed PLCs in documented cases. Patching: many vendors only release advisories, not patches, and Windows-based HMIs may be on Windows XP for licensing reasons. Compliance: Target was PCI-compliant when it was breached in 2013. Transition: “If those excuses don’t hold, who is actually coming after us?” — which sets up the threat pyramid.



Capability rises as we move up; volume of actors falls.

2026-05-18

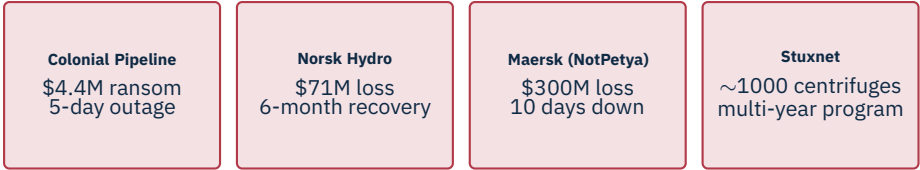
Industrial Security (Bachelor)

└ Threat Setting and Misconceptions

└ Threat Pyramid – Who Targets ICS?



Give each tier a face. Script kiddies: the Shodan-scanning teenager who finds an exposed VNC on a building automation system. Hacktivists: GhostSec / Anonymous publishing screenshots of Israeli and Iranian PLC web interfaces in 2022–2023. Cybercriminals: Conti, LockBit and Black Basta affiliates pivoting from IT into OT for leverage, as in JBS Foods 2021. Espionage: APT groups stealing recipes, set-points, and digital twins. Nation-state: Sandworm (GRU Unit 74455) behind Industroyer, Industroyer2, and the Ukraine grid attacks. Pre-empt the misconception that nation-state is the only thing worth defending against — ransomware crews cause the most actual downtime today. Ask: “Which tier are you most likely to face if you’re a mid-size water utility in Bavaria?” The answer is rarely nation-state and that matters for resource allocation. This motivates the cost slide next.



Direct + indirect

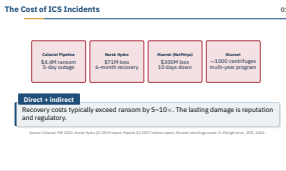
Recovery costs typically exceed ransom by 5–10×. The lasting damage is reputation and regulatory.

Source: Colonial: FBI 2021; Norsk Hydro Q1 2019 report; Maersk Q2 2017 interim report; Stuxnet centrifuge count: D. Albright et al., ISIS, 2010.

2026-05-18

- Industrial Security (Bachelor)
 - Threat Setting and Misconceptions
 - The Cost of ICS Incidents

These four are the canonical case studies you will keep returning to all semester. Colonial Pipeline (May 2021, DarkSide ransomware) was an IT-side breach via a leaked VPN password — the pipeline shut itself down because billing was on the IT network, which is itself a teaching moment about coupling. Norsk Hydro (March 2019, LockerGoga) is the gold-standard transparent-response case — they refused to pay, briefed press daily, and Klaus Mittelsten became the de facto poster child for “how to communicate during a breach.” Maersk’s NotPetya rebuild — 4000 servers, 45000 PCs in ten days — only worked because a domain controller in Ghana was offline due to a power cut. Stuxnet’s centrifuge count comes from David Albright’s ISIS analysis of IAEA inspection data; do not overstate it. Pre-empt “ransoms are the real cost” — the recovery, the lost production, and the regulatory follow-on dwarf the ransom every time. Transition: “So what is accelerating all of this?” — leading into Industry 4.0.





New attack surface

Every cloud connector is a new ingress – and a new authentication challenge for legacy field devices.

2026-05-18

Industrial Security (Bachelor)

Threat Setting and Misconceptions

Industry 4.0 – Convergence Pressure

Industry 4.0 is the German-coined term for the chain on this slide; the US-equivalent buzzword is Industrial IoT. Concrete examples land better than buzzwords: Siemens MindSphere (now Insights Hub), AWS IoT SiteWise, Azure Digital Twins, GE Predix. Each box on the chain is a different security domain – the PLC speaks Modbus, the edge gateway speaks MQTT, the cloud speaks REST with OAuth, and the ML layer ingests time-series with its own auth model. The legacy-auth point is concrete: a Siemens S7-300 has no notion of a user identity; bolting cloud-grade authentication onto it requires a gateway that becomes the trust anchor for the whole stack. Pre-empt the misconception that this is optional – predictive maintenance ROI is real and the business will deploy these connectors with or without security input. Question to provoke: “What does an attacker get from compromising the digital twin that they don’t get from the plant itself?” – often a better map of the plant than the operator has.



- **OT Security Engineer** – design, deploy, monitor controls; bridges IT and OT
- **Control Engineer with security focus** – starts from process side
- **ICS Penetration Tester** – offensive; specialised employers
- **Compliance / Audit** – IEC 62443, NIS2 specialist
- **Incident Responder (OT)** – on-call, often consulting-side (Dragos, Mandiant)
- **Researcher** – vendor / academic; vulnerabilities, threat intel

Demand

Headhunter reports consistently rank OT security in the top three hardest-to-fill cyber roles globally.

2026-05-18

Industrial Security (Bachelor)

└ Threat Setting and Misconceptions

└ Career Paths in Industrial Security

This is the slide to make eye contact for. The realistic on-ramp for most of the room is OT security engineer at a plant operator (E.ON, RWE, BASF, Bosch, Siemens Energy), or junior consultant at one of the boutique shops (Dragos, Claroty, Nozomi Networks, Admeritia, Limes Security). The control-engineer-pivots-to-security path is genuinely shorter than the IT-pivots-to-OT path because the process knowledge is the hard part to acquire. Pen testing in ICS is a tiny market — maybe a few hundred jobs globally — and getting in usually requires demonstrated home-lab work; this is what our labs in this course are partly preparing you for. Pre-empt the assumption that you need to be a deep electrical engineer — you need enough literacy to read a P&ID and talk to one, not to design one. Ask: “Who here has ever physically been inside a substation, a water plant, or a factory floor?” — the answer is usually “almost nobody,” and that is itself the opportunity. Transition: “Here’s the map of where we go from here.”

- **OT Security Engineer** – design, deploy, monitor controls; bridges IT and OT
- **Control Engineer with security focus** – starts from process side
- **ICS Penetration Tester** – offensive; specialised employers
- **Compliance / Audit** – IEC 62443, NIS2 specialist
- **Incident Responder (OT)** – on-call, often consulting-side (Dragos, Mandiant)
- **Researcher** – vendor / academic; vulnerabilities, threat intel

Demand
Headhunter reports consistently rank OT security in the top three hardest-to-fill cyber roles globally.

ICS & SCADA fundamentals
Network architectures
Industrial protocols
Threat landscape
Vulnerabilities & assessment
Risk management
Defense in depth
Standards & governance
Incident response

2026-05-18

- Industrial Security (Bachelor)
 - Threat Setting and Misconceptions
 - Section Roadmap

Section Roadmap

ICS & SCADA fundamentals
Network architectures
Industrial protocols
Threat landscape
Vulnerabilities & assessment
Risk management
Defense in depth
Standards & governance
Incident response

Walk top-to-bottom and flag the labs that go with each row so students see the through-line. Sections 1–3 are the vocabulary — if you cannot name a PLC, an HMI, a historian, an RTU, and Modbus / DNP3 / S7comm / OPC UA, the rest of the course is opaque. Sections 4–5 are where the room usually wakes up: real attacks, real CVEs, real shodan dorks. Section 6 (risk) is the one students underrate and practitioners rate highest — it is what they will actually do for a living. Section 7 maps directly to IEC 62443 zones and conduits. Section 8 is the bureaucratic glue that pays the bills. Section 9 closes the loop with incident response, which is where everything from sections 1–8 gets tested under stress. Pre-empt the question “why isn’t AI / ML its own section?” — it is woven through threat detection in 4 and anomaly detection in 9 rather than carved out separately. Transition: “Let’s wrap up what we covered today.”

★ Key Takeaway: Industrial security is different from IT security

- OT differs fundamentally from IT in goals, lifecycle, and tolerance for failure.
- Availability and safety dominate the CIA triad in industrial contexts.
- Adversaries today span from script kiddies to nation-state APTs.
- The next sections build the toolbox: components, networks, protocols, defenses.

2026-05-18

Industrial Security (Bachelor)

└ Threat Setting and Misconceptions

└ Summary – Section 01

Close on the one sentence you want them to repeat to a friend at dinner: industrial security is the security of systems whose failure mode is measured in lives, kilowatts, or barrels — not in records lost. Reinforce the inverted CIA triad as the single most portable concept from today — it is the answer to “why can’t we just use our IT playbook?” If you have time, name-check Stuxnet, Colonial, and Norsk Hydro once more so the case-study anchors stick. Pre-empt the “this is hopeless” mood that sometimes follows the threat slides — the next section starts the constructive part of the course by opening up the ICS itself. Optional engagement: ask the room for the one thing from today that surprised them most — the answers tell you which slide to lean into in next week’s recap.

★ Key Takeaway: Industrial security is different from IT security

- OT differs fundamentally from IT in goals, lifecycle, and tolerance for failure.
- Availability and safety dominate the CIA triad in industrial contexts.
- Adversaries today span from script kiddies to nation-state APTs.
- The next sections build the toolbox: components, networks, protocols, defenses.

- Albright, D., Brannan, P., Walrond, C. *Did Stuxnet take out 1,000 centrifuges at the Natanz enrichment plant?* ISIS, 22 Dec 2010.
- Falliere, N., Murchu, L., Chien, E. *W32.Stuxnet Dossier*, v1.4. Symantec, Feb 2011.
- FBI. *Statement on the Colonial Pipeline attack*, May 2021.
- GAO. *Critical infrastructure protection: Federal authorities for the Colonial Pipeline response*, GAO-22-104746, 2022.
- Norsk Hydro. *Q1 2019 Interim Report* (cyber-attack cost disclosure).
- A.P. Moller – Maersk. *Q2 2017 Interim Report* (NotPetya cost disclosure).
- NIST. *Cybersecurity Framework 2.0*, Feb 2024.
- ENISA. *Threat Landscape*, annual.
- Knapp, E.D., Langill, J.T. *Industrial Network Security*, 2nd ed., Syngress, 2014.
- Bodungen, C.E. et al. *Hacking Exposed: Industrial Control Systems*, McGraw-Hill, 2016.

End of Section 01

Introduction to Industrial Security

Questions and discussion

